# Industrial Security (Bachelor)

Solution Sheet – Section 05

Threat Landscape

## Exercise 5.1 – ATT&CK Mapping (Stuxnet sample)

| **Tactic** | **Technique ID** | **Detection idea** |
|---|---|---|
| Initial Access | T0862 Replication via removable media | USB telemetry; allow-list peripherals |
| Execution | T0871 Execution through API | Audit Step7 DLL load events |
| Persistence | T0859 Valid accounts | Alert on new admin sessions on eng WS |
| Lateral Movement | T0859 Valid accounts (SMB) | SMB anomaly detection between L2 and L3 |
| Inhibit Response | T0856 Spoof Reporting Message | Compare HMI tags vs raw PLC tags via diff |
| Impact | T0833 Modify parameter | PLC code change-control + checksum monitoring |

## Exercise 5.2 – Shodan observations

Typical findings: hundreds of Modbus endpoints (often building automation), bare Siemens PLCs without firewalls (residential PV inverters, water utilities), Unitronics PLCs with default port and password. Asset owners must remove direct Internet exposure, replace defaults, and use VPN/jump hosts. CERTs/ISPs can notify owners via WHOIS or sectoral channels (e.g. Shadowserver).

## Exercise 5.3 – Threat Modelling (sample)

Ranking for a regional speciality-chemicals site (most → least likely):

1. Cybercrime / ransomware (high financial motive, low cost).
2. Insider (former contractor).
3. Hacktivist (industry visibility).
4. Competitor / industrial espionage.
5. Nation-state APT (only if of strategic interest).

Sample ransomware path: phishing → corporate AD → vendor jump host → engineering WS → lateral to Historian → encryption. Choke points: MFA, EDR, segmentation between iDMZ and L2/3, offline backups.

## Exercise 5.4 – Supply Chain Response

Compensating controls: block ingress to vulnerable service on the firewall, deploy a virtual patch on the IPS, disable the vulnerable feature where possible, enable enhanced logging.
Inform: plant manager, OT/IT security leads, process safety, vendor account team, legal (in

case of regulatory disclosure).
Executive briefing: explain in business terms – “a critical flaw affects N PLCs; we have temporary controls in place that reduce, but do not eliminate, the risk. Vendor patch in $Q\ldots$, plant outage required.”